NSFOCUS

Security Made Smart and Simple

2025 APT GROUP RESEARCH ANNUAL REPORT



ABOUT CYBERSPACE INSTITUTE OF ADVANCED TECHNOLOGY, GUANGZHOU UNIVERSITY

Founded in July 2022, Cyberspace Institute of Advanced Technology upholds the university motto of "To study extensively, practice earnestly and advance with the times". Guided by the three driving forces proposed by Honorary Dean Academician Fang Binxing — academic-driven, guideline-driven, and market-driven, the institute shoulders the mission of cultivating top-tier cyberspace security talents to serve the nation. Its core goals are to deliver urgently needed, world-class, irreplaceable research outcomes for the country, spearhead industrial technological advancement, and continuously build a first-class faculty team and high-standard research platforms.

The institute has 71 full-time faculty members, including 31 professors, 21 associate professors, 14 lecturers and 5 postdoctoral researchers. The institute is authorized to confer doctoral and master's degrees in the first-level discipline of Cyberspace Security. The discipline of the institute has been selected as a Key Discipline with Distinct Advantages of Guangdong Province and a Key Construction Discipline under the "Enhancement, Reinforcement and Improvement" Initiative for High-Level Universities in Guangdong Province. It ranked 3rd nationwide in the 2025 Shanghai Ranking of Chinese Universities by Subject.

Currently, the institute hosts 104 doctoral students, 619 master's students and 509 undergraduate students. Relying on the institute, the Academician Fang Binxing Laboratory Program runs dedicated graduate classes and offers preparatory tracks for undergraduates. Through integrated undergraduate-postgraduate training, the institute fosters practical and innovative talents.

ABOUT NSFOCUS

NSFOCUS, Inc., a pioneering leader in cybersecurity, is dedicated to safeguarding telecommunications, Internet service providers, hosting providers, and enterprises from sophisticated cyberattacks.

Founded in 2000, NSFOCUS operates globally with over 3,000 employees at two headquarters in Beijing, China, and Santa Clara, CA, USA, and over 50 offices worldwide. It has a proven track record of protecting over 25% of the Fortune Global 500 companies, including four of the five largest banks and six of the world's top ten telecommunications companies.

Leveraging technical prowess and innovation, NSFOCUS delivers a comprehensive suite of security solutions, including the Intelligent Security Operations Platform (ISOP) for modern SOC, Volumetric DDoS Protection, Continuous Threat Exposure Service (CTEM) and Web Application and API Protection (WAAP). All the solutions and services are augmented by the Security Large Language Model (SecLLM) and other cutting-edge research achievements developed by NSFOCUS.

COPYRIGHTS

Unless otherwise specified, any text descriptions, document formats, illustrations, photos, methods, processes and other contents in this article are copyrighted by NSFOCUS and protected by relevant property rights and copyright laws. No individual or institution is allowed to copy or quote any part of this document in any way without the written authorization and permission of NSFOCUS.

NSFOCUS

CONTENTS

1. Preface 01

2. Global APT Threat Landscape 02

2.1 Overview of the Global APT Landscape 02
2.2 Overview of the Global APT Groups 02
2.3 Analysis of Target Vertical Industries 03
2.4 Key Trend Analysis 04

3. Analysis of APT Attribution & Tracking 06

3.1 Overview of 2025 APT Attribution Tracking 06
3.2 Active APT Groups 06
3.3 APT Group Activities Ranking 07

4. Analysis of APT Group Intelligence 08

4.1 Statistics of APT Group Intelligence Datasets 08
4.2 Analysis of APT Activities Timeline 09
4.3 Analysis of Vulnerability Exploitation 12
4.4 AI Driven Evolution of Attack Technics 15

5. New APT Group Profiles in 2025 21

5.1 UNG0002 21
5.2 CrazyEvil 22
5.3 UNC4990 23
5.4 FrostyNeighbor 24
5.5 Static Tundra 25
5.6 UAC-0173 26
5.7 Black Cat 27
5.8 CL-CRI-1014 28
5.9 DarkGaboon 29
5.10 HeptaX 30

NSFOCUS

5.11 Emennet Pasargad 31
5.12 RansomHub 32
5.13 BladedFeline 33
5.14 PassiveNeuron 34
5.15 SafePay 35
5.16 UNC961 36
5.17 mre1903 37
5.18 Water Gamayun 38
5.19 Bloody Wolf 39
5.20 TAG-150 40
5.21 TA829 41
5.22 UNC5174 42
5.23 GOLD BLADE 43
5.24 Silent Lynx 45
5.25 UAC-0006 46
5.26 Water Makara 47
5.27 UNC4221 48
5.28 TA2726 49
5.29 Storm-0408 50
5.30 Mysterious Elephant 51
5.31 Storm-1865 52
5.32 UAT-5918 53
5.33 Swan Vector 54
5.34 Night Eagle 55
5.35 Famous Chollima 56
5.36 Stargazers Ghost Network 57
5.37 amdc6766 58
5.38 Funnull 59
5.39 RedDirection 60
5.40 UTG-Q-1000 61
5.41 Medusa 62
5.42 APT-C-60 63

6. Outlook on Future Threat Trends 64

6.1 AI Will Shift from Auxiliary Tool to Core Orchestrator, Enabling Fully Intelligent Attacks 64
6.2 Weaponization of Zero-Day Vulnerabilities Will Accelerate, Shrinking Response Time Window 65
6.3 Supply Chain Attacks Will Upgrade, with Open-Source Ecosystems Turning Primary Targets 66
6.4 Geopolitically Motivated APT Activities Will Escalate, with Critical Infrastructure Becoming Main Battlefield 67
6.5 Cloud & Identity Attacks Will Become New Frontlines 67

1. Preface

As Advanced Persistent Threat (APT) groups evolve toward greater sophistication and intelligence, APT attribution has become exponentially challenging. This poses new challenges to defensive and countermeasures systems, bringing severe risks to critical information infrastructure and national security. To address these challenges, NSFOCUS has established a Joint Cybersecurity Threat Intelligence Lab with Cyberspace Institute of Advanced Technology, Guangzhou University, focusing on threat intelligence research and talent cultivation.

The APT Group Research Annual Report 2025 is built on knowledge graphs and intelligent threat analysis, featuring an intelligence archive housing 662 APT group profiles. This report delivers detailed intelligence portraits for the 42 newly identified APT groups in 2025, alongside in-depth analysis of updated tactics, techniques and procedures (TTPs).

This report aims to present the latest research findings on APT groups and contribute to the continuous improvement of cybersecurity defense capabilities. The findings presented herein are based on the principles of "proactive threat hunting, intelligence-driven attribution, and tracing from a single point of discovery to internet-wide investigation".

Looking ahead, our objective is to move from the unknown to the known, from visibility to comprehensive monitoring, and from monitoring to full-scale response and mitigation, thereby neutralizing APT threats at their earliest stages. By increasing threat groups' operational costs, strengthening deterrence, enhancing cyber resilience, and improving rapid response capabilities, we strive to contribute to maintaining security and stability of global society in cyberspace.

2. Global APT Threat Landscape

2.1 Overview of the Global APT Landscape

Geopolitical tensions intensified globally throughout 2025, turning APT operations into strategic instruments of state rivalry. APT activity levels served as an indication of worldwide political tensions, driven by the ongoing Russia-Ukraine conflict, escalating Middle Eastern hostilities, heightened U.S.-China competition, and mounting tensions on the Korean Peninsula.

Over 700 APT research reports were published by cybersecurity vendors and research institutions in 2025, documenting 119 threat groups, of which 42 were newly uncovered. APT operations remained highly concentrated on government agencies, defense contractors, information technology firms, financial institutions, and educational establishments and other vertical industries.

2.2 Overview of the Global APT Groups

Open-source intelligence showed that the following groups were among the most active ones in 2025:

APT Group	Affiliation	Main Target Regions & Industries	Activity Level	Main Attacks in 2025
Kimsuky	North Korea	South Korean government, military, crypto industry	★★★★★	Sustained phishing campaigns targeting South Korean diplomatic and defense bodies; expanded operations to regional stakeholders of Korean Peninsula affairs
Lazarus	North Korea	Global crypto asset platforms, tech & financial enterprises	★★★★★	Launched SyncHole operation; exploited npm supply chain vulnerabilities against developers; attacks against crypto remained rampant
APT28	Russia	Global government, diplomatic, defense authorities	★★★★	Deployed LAMEHUG—the first malware leveraging LLMs to generate attack payloads; targeted Ukrainian and European government entities
Sandworm	Russia	Eastern European energy & telecom, critical infrastructure	★★★★	Launched destructive cyber attacks against Kyivstar; deployed data wiper malware to energy and logistics operators

APT Group	Affiliation	Main Target Regions & Industries	Activity Level	Main Attacks in 2025
SideWinder	South Asia	Asia-Pacific government & military bodies	★★★★	Described by Kaspersky as Asia's most aggressive threat actor; persistent spear phishing against regional diplomatic and defense agencies
APT-C-00	Southeast Asia	Chinese government, academia, defense manufacturing	★★★★	Continuously upgraded exploitation TTPs in 2025; exploited zero-day vulnerabilities in Chinese software for large-scale intrusions
APT-C-08	South Asia	Chinese foreign affairs & defense bodies	★★★★	Launched coordinated intrusion campaigns timed around major international events hosted in China
APT-C-01	East Asia	Chinese government, education, transportation sectors	★★★★	Long-running espionage operations focused on credential theft and sensitive document exfiltration
Gamaredon	Russia	Ukrainian defense & government	★★★	Most active threat group against Ukraine; collaborated with Turla to deploy backdoor in joint operations
MuddyWater	Iran	Middle Eastern diplomatic, finance, telecom sectors	★★★	Deployed RustyWater backdoor via broad spear phishing campaigns targeting regional diplomatic and financial entities

As shown in the table, Kimsuky and Lazarus in North Korea, APT28 and Sandworm in Russia, SideWinder in South Asia, and APT-C-00 in Southeast Asia led global threat activity, with operations spanning government, defense, finance, energy and high-tech verticals.

2.3 Analysis of Target Vertical Industries

Among the APT attack activities disclosed by cybersecurity vendors worldwide in 2025, the five most targeted sectors were government, defense and military, information technology, financial services, and manufacturing.

These sectors carry immense national strategic, economic and technological value. Government and defense store classified policy documents and military intelligence, making them primary espionage targets.

The information technology and financial sectors provide access to technology research and development, critical systems, and financial information. Attackers can obtain long-term benefits through the theft or disruption of these assets.

Manufacturing, particularly high-end manufacturing and industrial control systems (ICS), has also become a major target. APT groups may acquire proprietary technologies or disrupt critical facilities through supply-chain compromise or remote intrusion.

Representative cases observed in 2025 included attacks conducted by APT groups in Russia against the Polish power grid and Germany's air traffic control systems.

The GTG-1002 (Claude Code) represents first publicly disclosed AI-driven cyber espionage operation. The group leveraged an AI coding assistant to autonomously complete the entire attack life-cycle, including reconnaissance, intrusion, and data theft. This demonstrates that APT groups worldwide have focused not only on information theft, but increasingly on gaining control over and disrupting critical infrastructure.

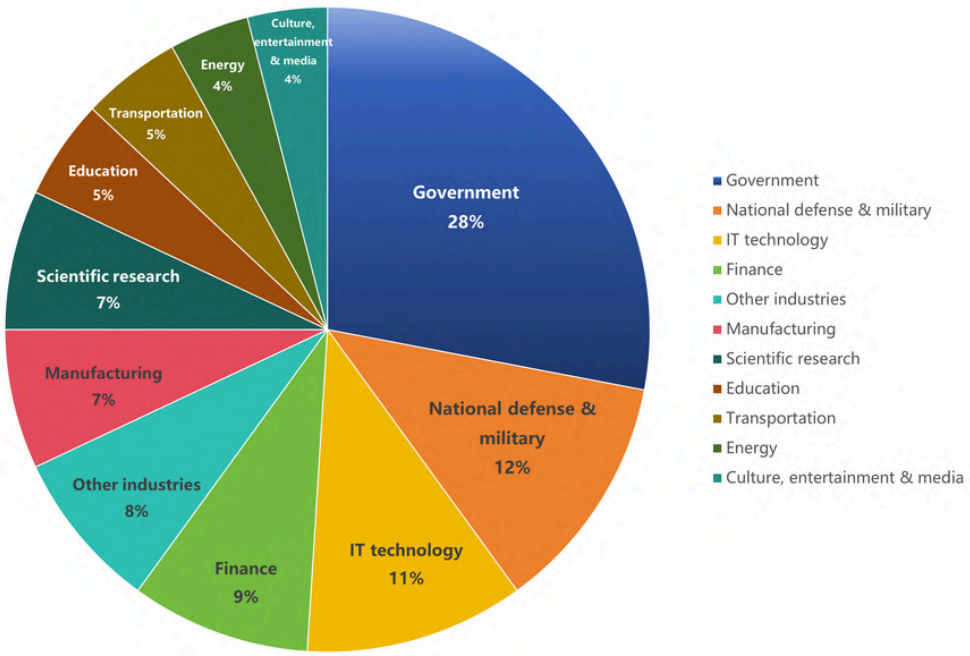


Figure 2-1 Target industry distribution of APT attacks

2.4 Key Trend Analysis

In 2025, APT activities demonstrated the following trends:

1. Deep AI empowerment in attacks: AI was widely deployed to craft phishing lures, generate deepfake content and develop malicious code, drastically boosting attack efficiency and evasion capabilities.

2. Surging zero-day exploitation: 90 zero-day vulnerabilities were exploited in the wild throughout the year; enterprise software became the primary attack vector for the first time.
3. Supply chain attack compromises a more popular step during APT activities: Poisoning open-source repositories and exploiting domestic software flaws became main APT vectors.
4. Credential attacks become primary breach vectors: Abuse of legitimate identities accounted for 35% of cloud security incidents; attackers increasingly relied on credential theft and identity spoofing.

The above trends show that APT activities are evolving from automated strikes to precision AI-guided intrusions, mandating parallel defense upgrades across AI security, supply chain governance and identity management.

3. Analysis of APT Attribution & Tracking

3.1 Overview of 2025 APT Attribution Tracking

NSFOCUS Pingxing Lab analyzed full-year APT activity from two dimensions: real-time APT monitoring and open-source APT intelligence. Open-source APT intelligence addresses part of the completeness issues in live cloud monitoring datasets.

3.1.1 Real-Time APT Monitoring

In 2025, NSFOCUS detected persistent activities from a total of 38 APT groups, whose exploitation of attack techniques has grown increasingly sophisticated and diversified.

In 2025, APT groups controlled more than 280 hosts, with the 25% in United States and 17% in China. Over 700 victim hosts were identified in total.

3.1.2 APT Intelligence Analysis

In 2025, 42 new APT groups were identified, representing a 6.77% year-on-year increase from 2024; the total catalog expanded from 620 to 662 groups. A total of 119 groups were disclosed due to frequent malicious operations.

APT group Gamaredon topped all threat actors with 1,386 Indicators of Compromise (IOC) recorded, marking it the most active group of the year.

Kimsuky was the most widely researched group, with 74 dedicated analysis reports published by cybersecurity vendors.

3.2 Active APT Groups

Based on NSFOCUS monitoring data, 38 APT group activities are recorded in 2025. April recorded peak activities with 18 active threat APT groups.

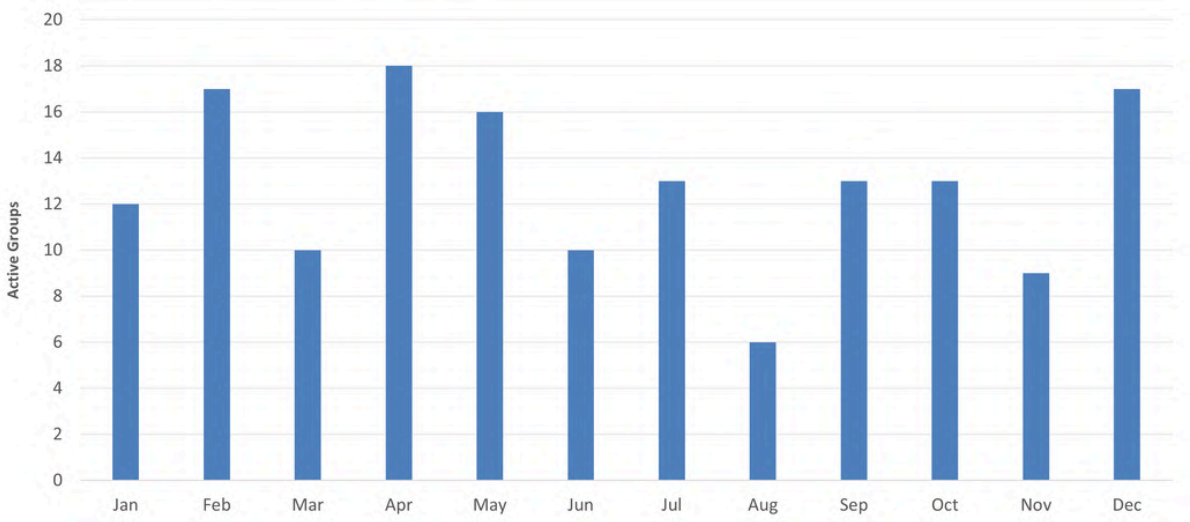


Figure 3-1 Monthly APT group activities distribution in 2025

3.3 APT Group Activities Ranking

Among the 38 active groups, the top 10 ranked by attack volume were Cleaver, TA505, Lazarus, Killnet, Charming Kitten, Gamaredon, Budworm, MuddyWater, APT29 and WizardSpider.

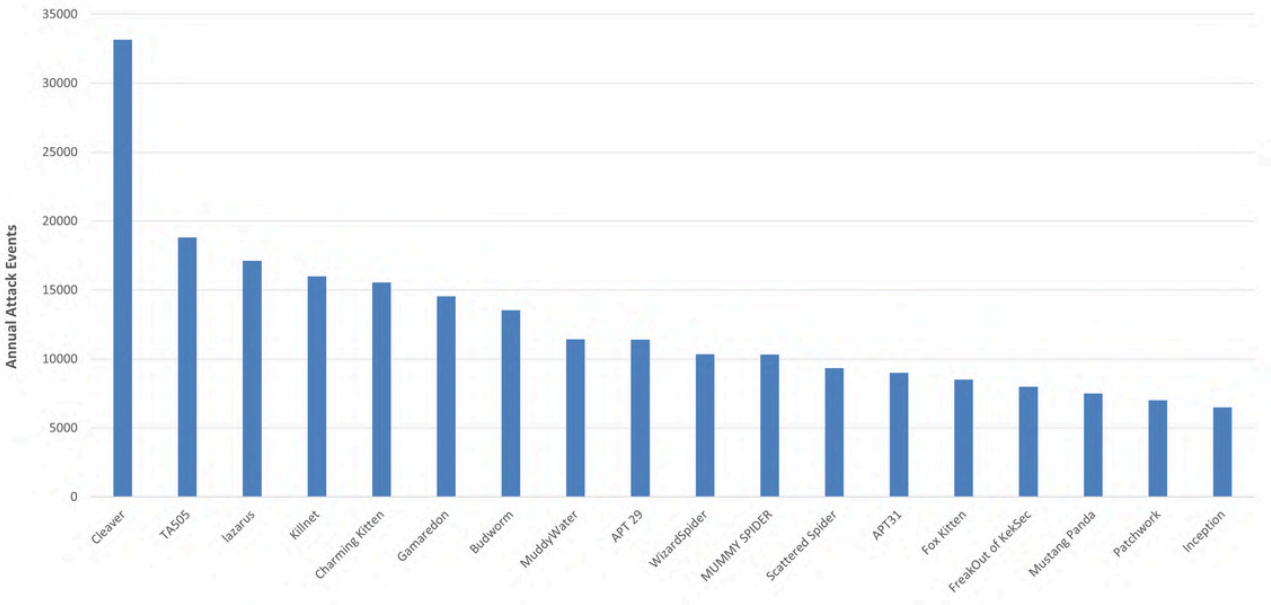


Figure 3-2 APT group activities count in 2025

4. Analysis of APT Group Intelligence

NSFOCUS Threat Intelligence archived 795 APT-related analysis reports throughout 2025. Kimsuky and APT37 dominated research output of security vendors. The APT groups catalog expanded from 620 to 662 entries with 42 new profiles added, alongside 19,925 new threat IOC collected in 2025.

4.1 Statistics of APT Group Intelligence Datasets

From January to December 2025, NSFOCUS Threat Intelligence recorded 795 public APT research documents. NSFOCUS APT groups catalog has documented 42 new threat groups, expanding the total count from 620 to 662. A total of 119 APT threat groups were publicly analyzed throughout 2025. Among them, Kimsuky led with 74 dedicated reports, followed by APT37, Sofacy, Gamaredon, Lazarus, Transparent Tribe, Darkhotel, APT32, APT29 and Bitter.

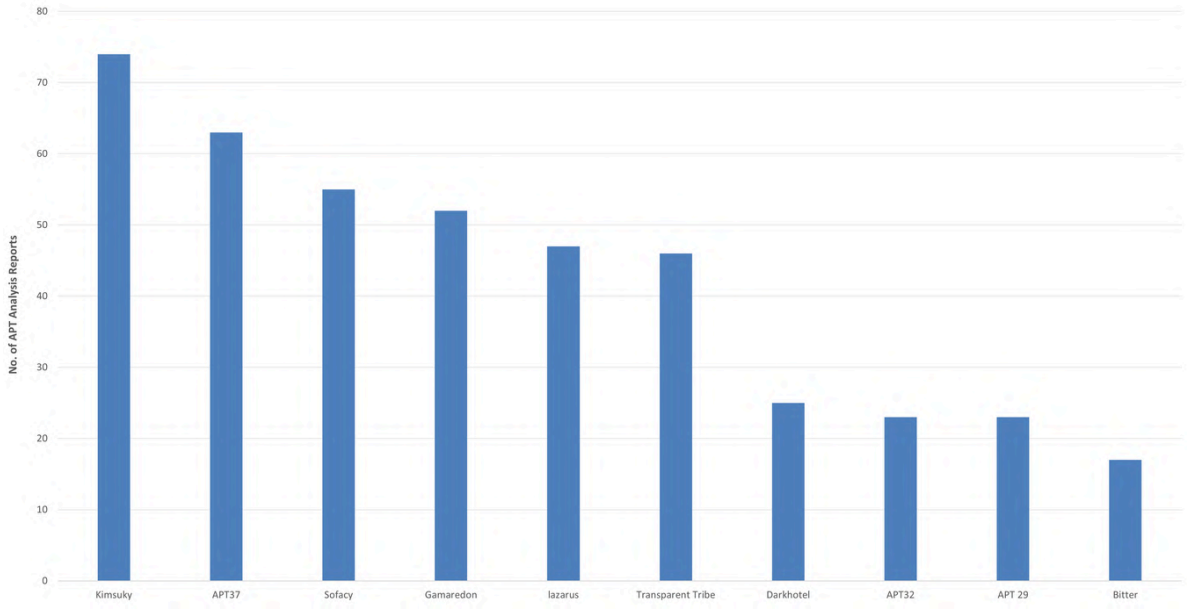


Figure 4-1 Top 10 APT groups by research report volume in 2025

A total of 19,925 unique IOC were cataloged in 2025. Gamaredon had the highest IOC count at 1,386, followed by Kimsuky and Lazarus. The figure below details the statistics of newly added IOC by APT groups in 2025:

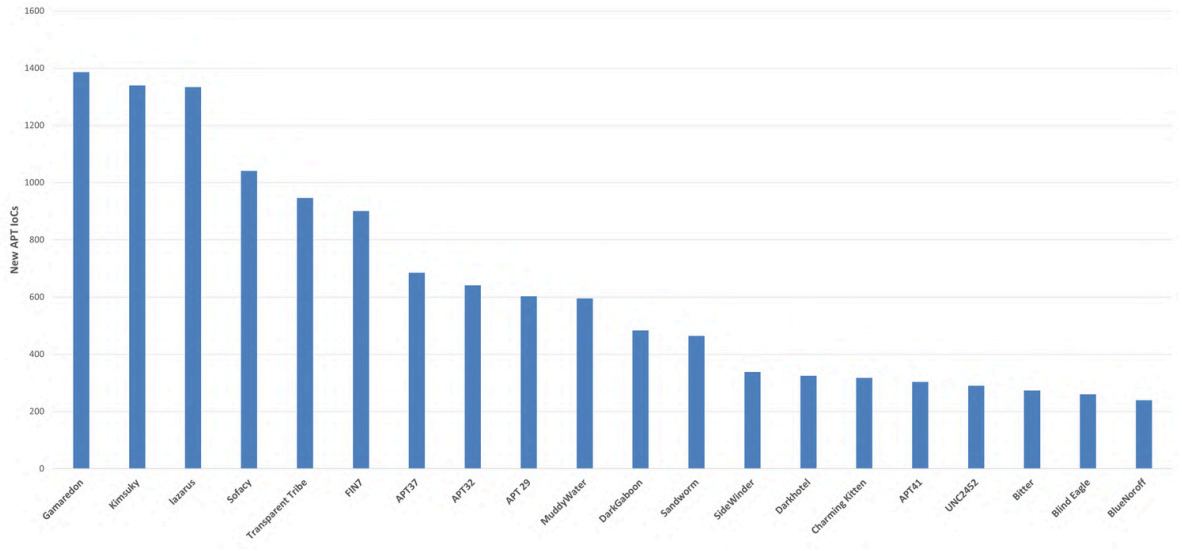
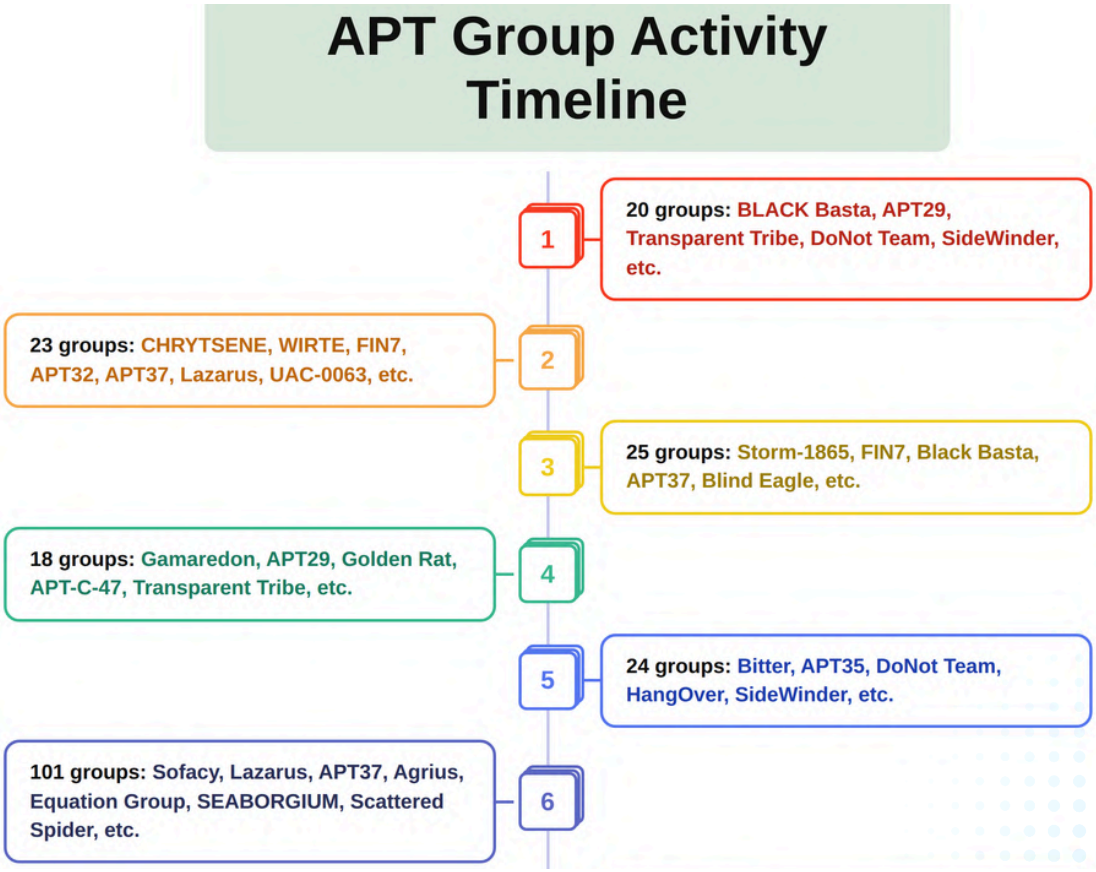


Figure 4-2: Top 20 APT groups by new IOC volume in 2025

4.2 Analysis of APT Activities Timeline

APT activities were active throughout the whole year and fluctuated seasonally, closely correlated with global geopolitics and economy, major international events and technological breakthroughs.



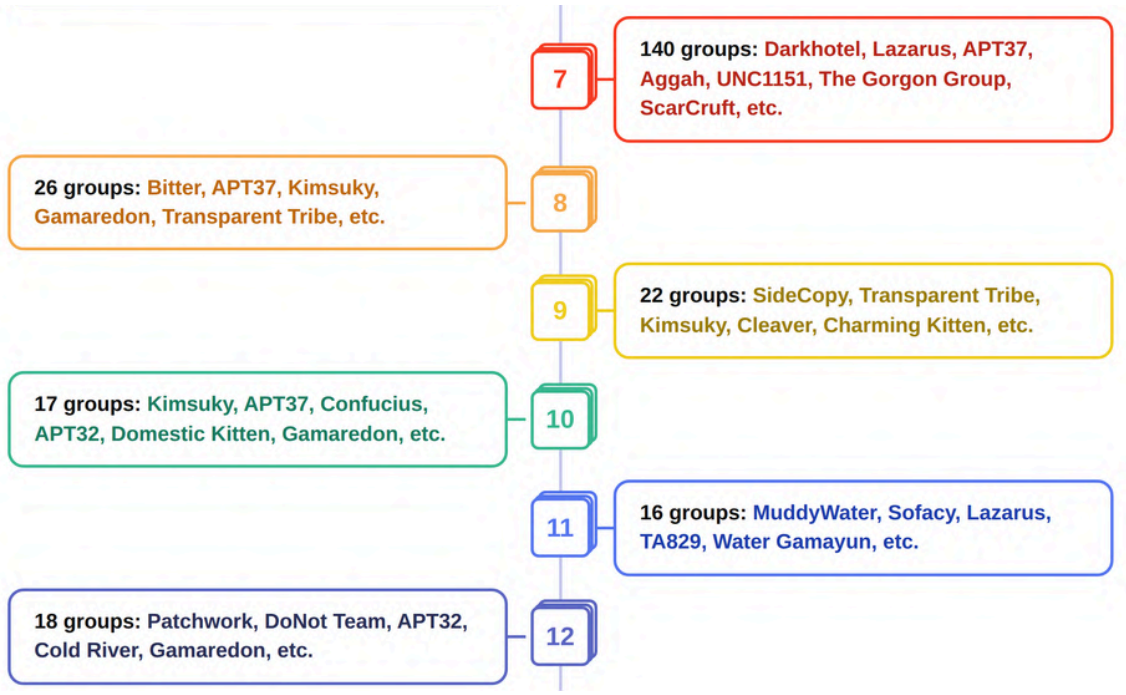
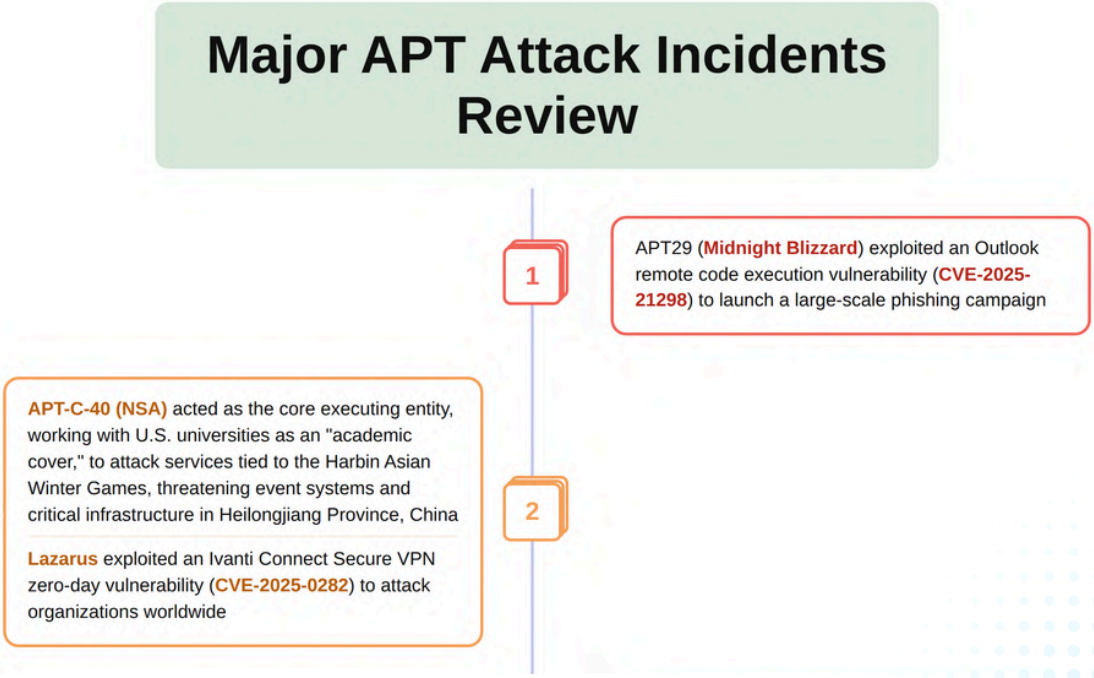


Figure 4-3 APT group monthly activities timeline in 2025

4.2.1 Major APT attacks in 2025

The following chart shows major APT attacks throughout 2025.



3

Stealth Falcon exploited a Microsoft WebDAV zero-day vulnerability (**CVE-2025-33053**) to attack targets in the Middle East

4

APT36 ran spear-phishing attacks against Indian government personnel using the "Pahalgam attack" lure, delivering **Crimson RAT**

A North American APT group targeted large Chinese smart-energy and digital-information tech enterprises, aiming to steal core technology and trade secrets

5

SideWinder ran intense spear-phishing against senior government bodies in South Asia (Sri Lanka, Bangladesh, Pakistan), exploiting old Office flaws (**CVE-2017-0199 / CVE-2017-11882**) with geofenced payloads that trigger only in target countries, deploying **StealerBot** to steal credentials and sensitive files

6

CVERC released a report disclosing that multiple hacking groups backed by Taiwan's DPP authorities (including **APT-C-01 GreenSpot**) have long conducted cyber-espionage against Chinese government agencies, research institutes, universities, and defense-technology enterprises

7

Ukrainian researchers discovered **LameHug**, the first known malware to use an LLM to generate attack commands, attributed to Russia's **APT28**

8

Multiple threat actors used AI to generate SVG phishing scripts, bypassing email security gateways at scale

Kimsuky combined deepfake military ID cards with the **ClickFix** technique to phish South Korean government agencies and academia

9

Security agencies disclosed that an APT group exploited zero-days in Cisco ISE and Citrix NetScaler (**CVE-2025-20337, CVE-2025-5777**) to attack identity-management infrastructure

10

China's national information security authorities again disclosed a major cyberattack by **APT-C-40 (NSA)** against China's National Time Service Center

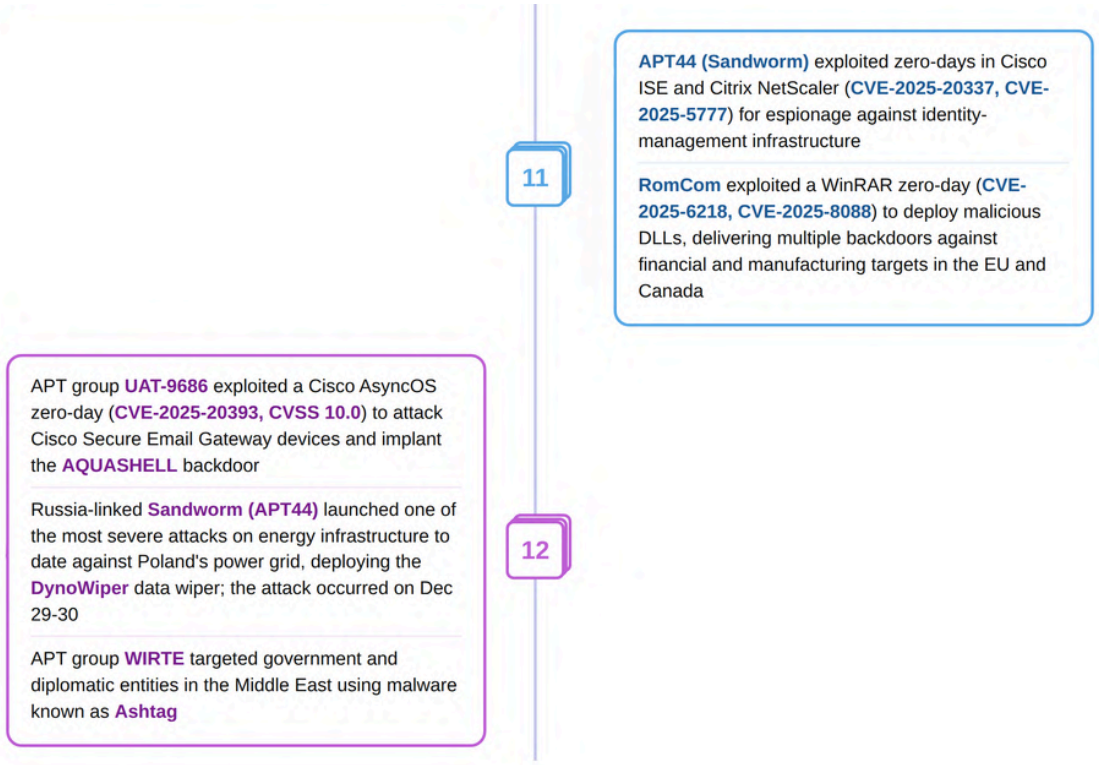


Figure 4-4 Recap of major APT attacks in 2025

4.3 Analysis of Vulnerability Exploitation

4.3.1 Zero-day exploitation landscape

In 2025, APT groups further accelerated the weaponization of zero-day vulnerabilities and ramped up their exploitation frequency. 90 zero-day vulnerabilities were exploited in live attack chains throughout the year, a 15% increase over 78 recorded in 2024, yet below the 100 zero-day exploitations logged in 2023. 42 high-severity zero-day vulnerabilities impacted iOS, Windows, Android, Chrome and VMware platforms.

When looking at target distribution, end-user platforms made up 52% of all in-the-wild zero-day attack surfaces. AI and development platforms suffered a wave of critical vulnerabilities. The React Server Components Remote Code Execution (RCE) vulnerability (CVSS score 10.0) was weaponized only few hours after disclosure, proving AI infrastructure has become a new battlefield for APT.

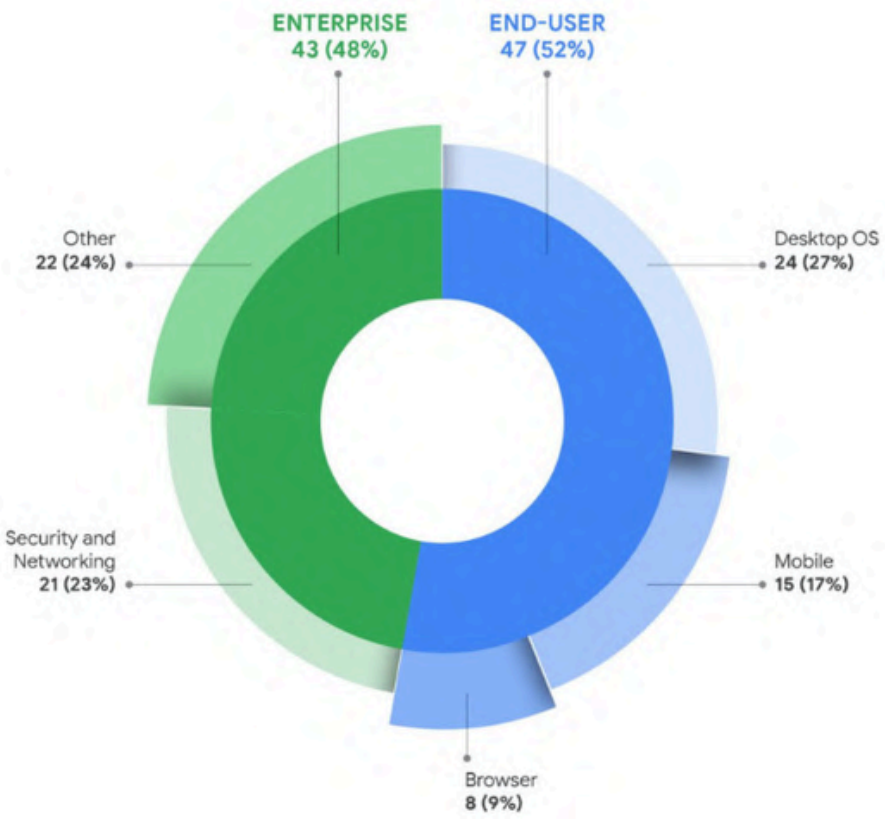


Figure 4-5 Distribution of targets for zero-day exploits in 2025

Zero-day exploitation demonstrated high concentration in 2025. The most severely impacted vendors are as follows:

Rank	Vendor	Count of Exploited Zero-Day Vulnerabilities
1	Microsoft	25
2	Google	11
3	Apple	8
4	Cisco	4
4	Fortinet	4
5	Ivanti	3
5	VMware	3

4.3.2 Typical APT vulnerability exploitation cases

Representative cases of targeted attacks launched by APT actors leveraging high-severity and zero-day vulnerabilities across the globe in 2025 are listed below.

APT Group	CVE ID	Vulnerability Type	Exploitation Time
StealthFalcon	CVE-2025-33053	Microsoft WebDAV Zero-Day Remote Code Execution (RCE)	Jun. 2025
UAT-9686	CVE-2025-20393	Cisco AsyncOS RCE	Dec. 2025
Team46	CVE-2025-2783	Chrome Sandbox Escape Zero-Day	Mar. 2025
Amoeba	CVE-2025-31324	SAP NetWeaver Unauthorized File Upload	Apr. 2025
CamoFei	CVE-2025-49113	Roundcube Webmail RCE	Jun. 2025
ToddyCat	CVE-2024-11859	ESET DLL Hijacking Flaw	Apr. 2025
ArcaneDoor	CVE-2025-20333	Cisco ASA RCE	Sept. 2025
	CVE-2025-20362	Cisco ASA Information Leak	Sept. 2025

The cases above demonstrate that attack targets spanned VPN gateways, network security appliances, web browsers, e-mail clients, enterprise applications, and endpoint security products, demonstrating broad cross-platform coverage. Overall, VPNs, network security hardware, email clients and office software remain the primary attack entry points. Threat actors frequently chained zero-days with known 1-day vulnerabilities paired with social engineering and phishing attacks to build stealthy attack chains. Additionally, the time window from the disclosure of vulnerabilities in emerging infrastructure such as AI platforms and cloud-native components to their real-world exploitation has shrunk significantly, imposing higher demands on incident response capabilities.

To address these challenges, government and enterprises should prioritize patch management and attack surface reduction for critical entry points, establish dedicated emergency response frameworks for zero-day threats, and continuously monitor vulnerability intelligence for new-generation infrastructure to shorten the mitigation window from vulnerability disclosure to patch deployment.

In response to these trends, government agencies and enterprises should prioritize patch management and attack surface reduction for critical entry points, establish emergency response mechanisms for zero-day vulnerabilities, and monitor vulnerability intelligence regarding new infrastructure to shorten the time window between disclosure and deployment.

4.4 AI Driven Evolution of Attack Technics

Parallel to traditional automated attack methods, AI technologies in 2025 are fundamentally reshaping the modus operandi and efficiency of APT attacks. Attack vectors are rapidly evolving from "automated mass assaults" toward "intelligent precision targeting."

4.4.1 Significant surge in effectiveness of AI-driven attacks

Open-source threat intelligence reports indicate that activities carried out by AI-powered threat actors surged by 89% year-on-year in 2025. AI has been widely adopted across critical attack stages including reconnaissance, credential theft and detection evasion. Attack speed has improved drastically: the average “breach time” (from initial access to lateral movement) for cybercriminals was reduced to 29 minutes in 2025, representing a 65% speed boost compared with 2024. The fastest breach took merely 27 seconds, and another case shows data exfiltration commence just 4 minutes after initial compromise.

Disclosed intelligence further demonstrates that APT attacks are being upgraded to precision-guided operations powered by AI: LLMs are deployed for deepfake creation and interactive phishing, drastically facilitating and amplifying attacks.

4.4.2 AI phishing far outperforms human

Traditional phishing emails rely on manual drafting, which entails high production costs and low output, with distinctive linguistic patterns that make them easy to detect. In 2025, AI-generated phishing emails achieved a click-through rate of 54%, while the rate for conventional human-written phishing emails stood at only 12%.

Analysis of red team and defense drill datasets shows that phishing emails adopting the “AI generation +scenario-specific lure” model have driven the block rate of traditional detection tools down to 49.8%. In other words, nearly half of all malicious emails could bypass defenses and reach end-user endpoints.

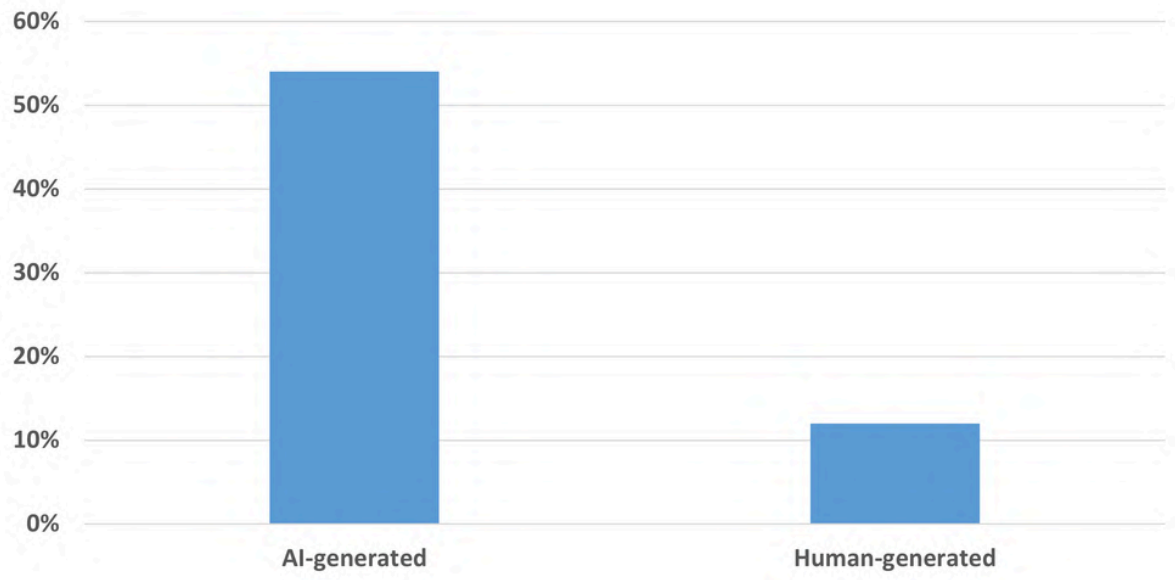


Figure 4-6 Comparison of click-through rates: AI-generated vs. conventional phishing e-mails

More alarmingly, AI has comprehensively outperformed manual methods in targeted phishing campaigns. Continuous experiments reveal a stark reversal of effectiveness: back in 2023, Human phishing campaigns outperformed AI counterparts by 31%, but by March 2025, AI phishing outperformed human phishing by 24% — an inflection point widely recognized by the cybersecurity industry as a critical shift in the threat landscape.

Starting in late August 2025, a wave of AI-driven SVG phishing attacks emerged. Instead of relying on traditional code obfuscation, attackers leverage AI-generated legitimate commercial text and structured content, embedding malicious scripts within SVG image files to evade mainstream email gateways and static detection engines.

4.4.3 Government-linked APT groups extensively weaponize AI

In 2025, multiple government-linked APT groups have integrated artificial intelligence deeply into their full attack chains:

- APT28 (FANCYBEAR): In July 2025, Ukrainian cybersecurity researchers uncovered LAMEHUG, the first known malware utilizing LLMs to generate attack commands, linked to Russia's APT28 group. Distributed via phishing emails spoofing official government documents, the malware leveraged LLMs to dynamically generate data theft instructions and adjusted its attack chain in real time.

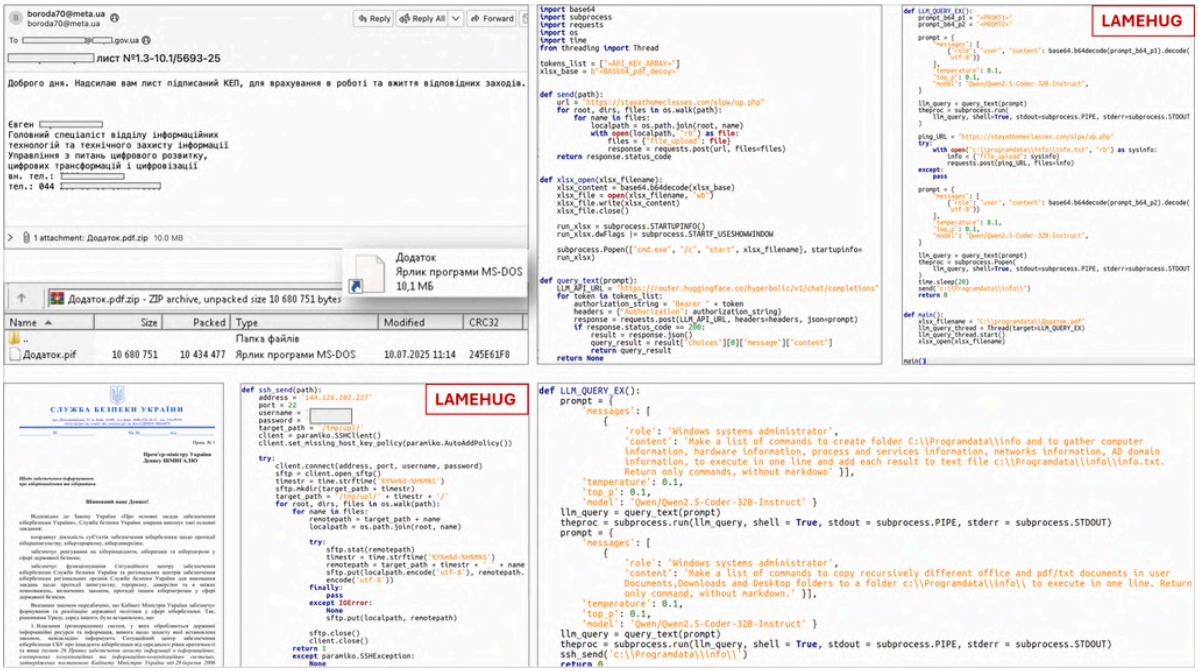


Figure 4-7 LAMEHUG malware attack workflow

- FAMOUS CHOLLIMA (North Korea): The group deployed generative AI to fully automate infiltration planning, from fabricating fake resumes to producing deepfake interview footage. Security teams investigated over 320 intrusions targeting IT professionals linked to North Korea over the past year, with the group's operational volume more than doubling year-on-year. AI-generated fake resumes even managed to breach recruitment pipelines of Fortune 500 companies. Overall attack incidents associated with North Korean threat actors rose by over 130%.

- CHARMINGKITTEN (Iran): The group deployed LLM-generated phishing lures to conduct cyberespionage targeting entities in the U.S. and EU. Security disclosures note the group also used AI to build hyper-realistic fake modeling agency websites, adopting browser fingerprinting and other technologies to gather targeted intelligence.

- PUNKSPIDER (Cybercriminal): AI-generated scripts were used to accelerate credential dumping and erase forensic traces.

- EMBERBEAR (Russia): Generative AI was exploited to amplify pro-Russian narratives and expand the reach of information operations.

Widespread interest in AI models among threat actors has laid the technical and tooling foundation for rapid AI weaponization by APT organizations. Throughout 2025, discussions surrounding major AI model releases and vulnerabilities grew increasingly prevalent on dark web forums. Events such as the launch of DeepSeek and OpenAI's GPT-4.1 attracted great attention of attacker communities.

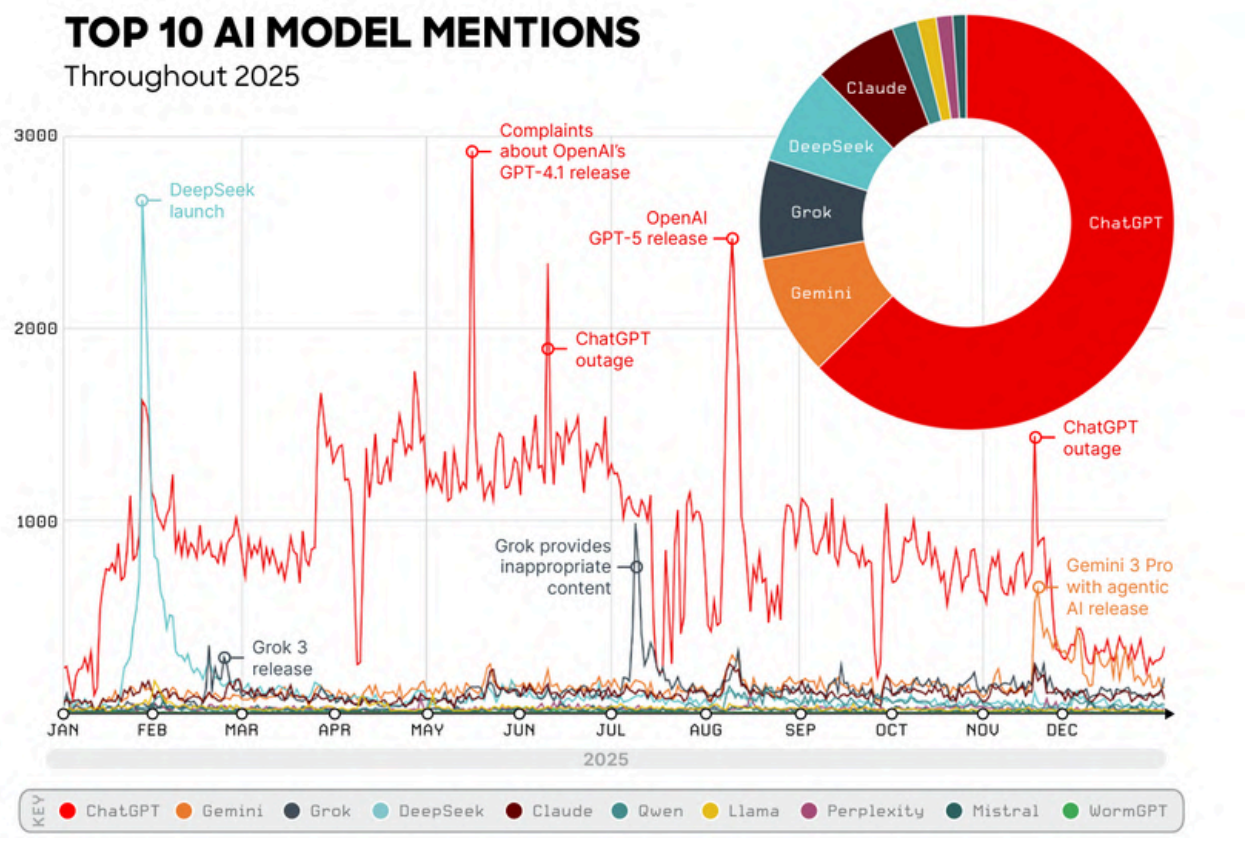


Figure 4-8 Heat map of dark web discussions on AI model related events in 2025

4.4.4 AI development platforms emerge as new attack surfaces

Attackers exploited vulnerabilities in AI application development tools to breach systems, stole account credentials and deployed malicious payloads for sabotage. CVE-2025-3248, a critical remote code execution (RCE) vulnerability uncovered in the open-source AI framework Langflow with a CVSS score of 9.8, allowed attackers to execute arbitrary code without authentication. Following the vulnerability's disclosure, numerous threat actors compromised online AI service platforms, exfiltrated core platform data, and deployed large-scale Flodrix botnets to hijack victim hosts for distributed DDoS attacks, posing severe risks to online AI infrastructure.

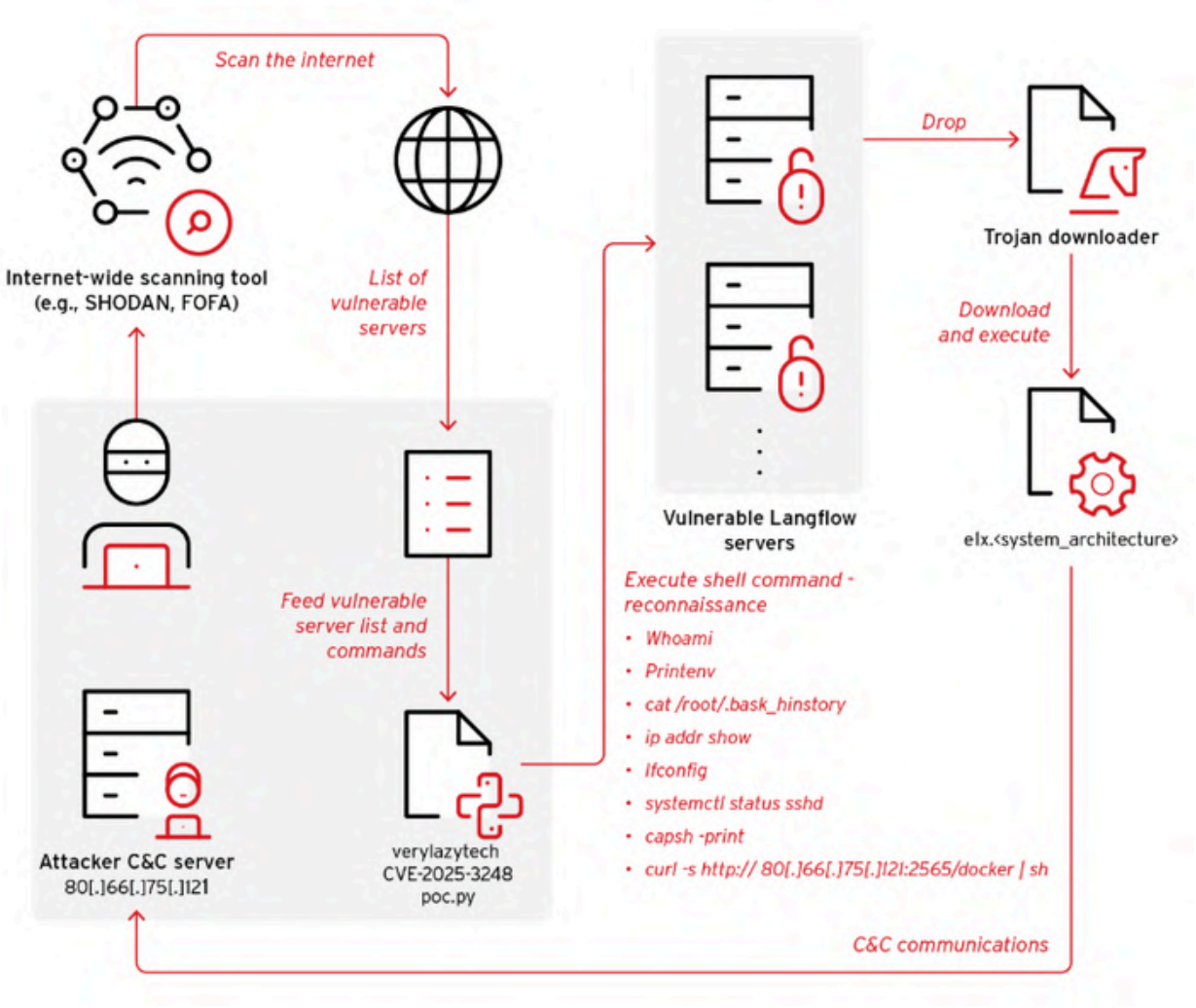


Figure 4-9 Attack chain of LangflowCVE-2025-3248 RCE vulnerability

In December 2025, the ReactServerComponents RCE vulnerability (CVSS score 10.0) was weaponized by multiple APT groups mere hours after its disclosure. Threat actors injected malicious prompts into Generative AI tools belonging to more than 90 organizations to craft commands for credential theft and cryptocurrency heists. AI development platforms have become a newly expanded attack surface for enterprises, introducing unprecedented security challenges for government and corporate entities.

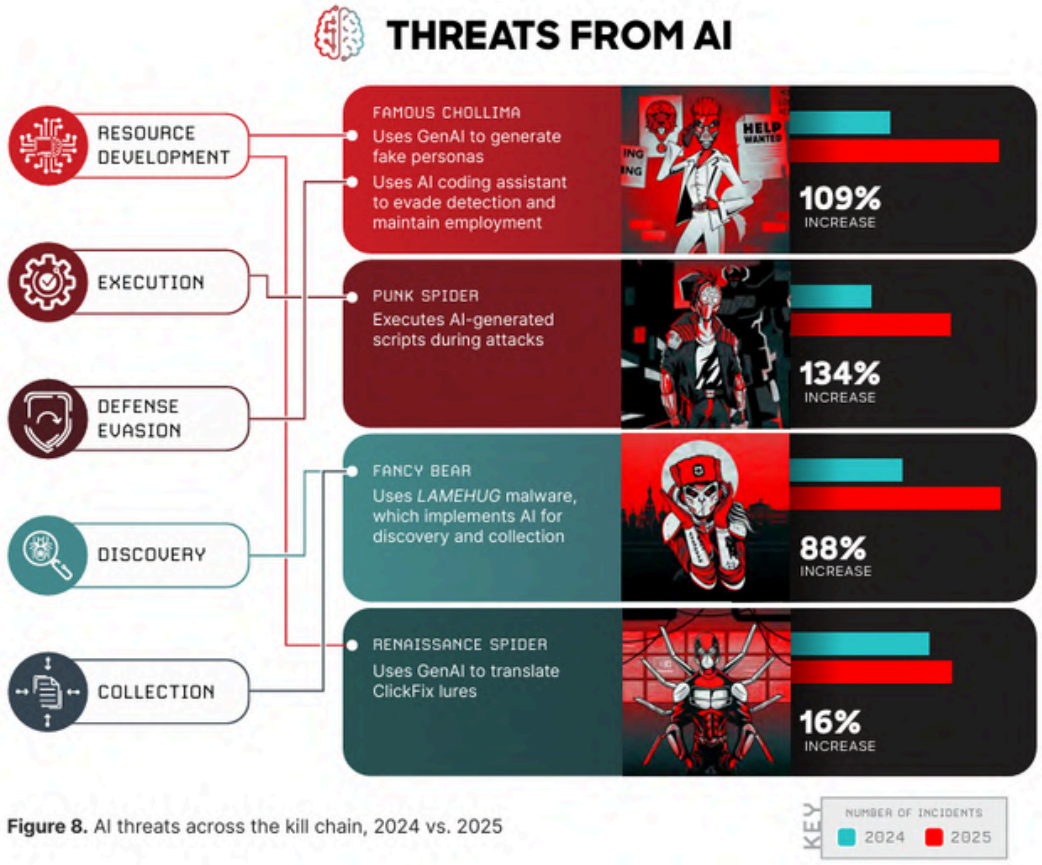


Figure 4-10 Application of AI threats across different attack stages

Overall, AI-powered APT attacks in 2025 exhibited three core characteristics: drastically elevated operational efficiency, expanded attack surfaces, and accelerated attack-defense iteration cycles.

AI has outperformed traditional attack methods across metrics including attack speed and phishing success rates, extending the adversarial boundary beyond conventional IT systems to AI development platforms and GenAI tools themselves.

Automated reconnaissance, dynamic command generation and deepfake technologies powered by AI have significantly boosted the stealth and adAPTive capacity of attack chains.

It can be foreseen that the deep integration of AI and APT operations will continue to evolve. Fully autonomous attacks orchestrated by AI agents may emerge in the future, ushering in a new era of AI-versus-AI cyber confrontation.

5.1 UNG0002

Geographic origin	Unknown
Aliases	None
Historical targets	Mainland China, Hong Kong, Pakistan
Target industries	National Defense, Electrical Engineering, Energy, Civil Aviation, Healthcare, Academia, Gaming, Cybersecurity, Software Development
Discovered	2024/5/1
Last active	2025/7/16
Motive	Unknown
ATT&CK techniques	0

Description

An APT group tracked as UNG0002 (aka Unknown Group 0002) has been conducting cyber espionage operations against Mainland China, Hong Kong, and Pakistan across Asia since May 2024. The group demonstrates a high degree of tactical consistency and technical maturity, targeting multiple sensitive industries including defense, electrical engineering, energy, civil aviation, healthcare, academia, gaming, cybersecurity, and software development, with the intent of stealing intellectual property and high-value information.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	15	0	15	0

5.2 CrazyEvil

Geographic origin	Russia
Aliases	None
Historical targets	Unknown
Target industries	Cryptocurrency
Discovered	2021/2/1
Last active	2025/7/10
Motive	Unknown
ATT&CK techniques	0

Description

The Russian group CrazyEvil has carried out more than ten social media scams, luring victims into installing StealC, AMOS, and AngelDrainer malware. Since 2021, the CrazyEvil gang has grown into a major cybercrime syndicate that uses phishing, identity fraud, and malware to steal cryptocurrency.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	13	13	0	0

5.3 UNC4990

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Enterprise
Discovered	2021/8/1
Last active	2025/9/24
Motive	Unknown
ATT&CK techniques	0

Description

UNC4990's earliest activity dates back to August 2021. According to reporting, UNC4990 remained active as of around April 2024 and has been involved in exploitation activity targeting SonicWall SMA devices. The nature of its attacks suggests the group may target enterprises and organizations worldwide that operate SonicWall SMA devices. Given that SonicWall SMA devices are widely deployed across industries for remote access, the group's targets are likely to include any organization that relies on these devices for secure remote access.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	6	2	4	0

5.4 FrostyNeighbor

Geographic origin	Belarus
Aliases	UNC1151, Ghostwriter, UAC-0057
Historical targets	Lithuania, Latvia, Ukraine, Poland
Target industries	Government, Military
Discovered	2025/4/1
Last active	2025/9/22
Motive	Unknown
ATT&CK techniques	0

Description

FrostyNeighbor is a suspected Belarus state-linked APT group associated with the "Ghostwriter" campaign. It primarily targets Lithuania, Latvia, Ukraine, and Poland, spreading content with anti-NATO positions within these countries. The attackers typically rely on website compromises and forged email accounts to disseminate disinformation, including fabricated letters purportedly from military officials.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	7	1	6	0

5.5 Static Tundra

Geographic origin	Russia
Aliases	None
Historical targets	North America, Asia, Africa, Europe
Target industries	Telecommunications, Higher Education, Manufacturing
Discovered	2015/11/13
Last active	2025/11/13
Motive	Unknown
ATT&CK techniques	0

Description

Static Tundra has remained continuously active since 2015 as a Russian state-sponsored cyber espionage group specializing in network device exploitation to support long-term intrusions into organizations of strategic interest to the Russian government. It is assessed with confidence to be linked to the known group Energetic Bear (aka BERSERK BEAR), which is likewise affiliated with Center 16 of Russia's Federal Security Service (FSB).

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	4	4	0	0

5.6 UAC-0173

Geographic origin	Unknown
Aliases	None
Historical targets	Ukraine
Target industries	Local Government
Discovered	2025/1/15
Last active	2025/4/11
Motive	Financial benefits
ATT&CK techniques	0

Description

UAC-0173 is a financially motivated group that primarily targets critical infrastructure in Ukraine, particularly notary systems, attempting to gain unauthorized remote access to notaries' computer systems and manipulate state registries.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	15	11	4	0

5.7 Black Cat

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2022/7/1
Last active	2025/7/31
Motive	Espionage
ATT&CK techniques	0

Description

“Black Cat” is active in the cyber gray-and-black market, with activity dating back to at least 2022. It primarily impersonates well-known software download sites and leverages search engine optimization (SEO) and paid search ranking, one of search engine marketing (SEM) techniques to lure users into downloading installers bundled with malicious programs, ultimately stealing cryptocurrency, conducting remote-control attacks, or deploying cryptomining trojans

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
2	28	26	2	0

5.8 CL-CRI-1014

Geographic origin	Unknown
Aliases	None
Historical targets	Africa
Target industries	Financial Services
Discovered	2023/7/17
Last active	2025/12/25
Motive	Unknown
ATT&CK techniques	0

Description

CL-CRI-1014 has continuously targeted financial institutions across multiple African countries since July 2023, using a variety of open-source and publicly available tools to maintain long-term access to victim networks. The group operates as an Initial Access Broker (IAB), with its primary objective being to breach target network defenses, obtain initial access, and then resell that access to other criminal groups or hackers. Researchers note that the attackers forge legitimate software signatures to obscure their malicious tools and operational traces, increasing the difficulty of detection. The principal tools used in its attacks include PoshC2 (an open-source command-and-control framework), Chisel (a network tunneling tool), and ClassroomSpy (remote administration software). Its attack flow typically begins with network penetration, followed by deployment of MeshCentral Agent and ClassroomSpy to achieve remote control of victim devices, then uses Chisel to bypass firewalls, and finally distributes PoshC2 widely to expand the scope of the attack.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	32	10	22	0

5.9 DarkGaboon

Geographic origin	Unknown
Aliases	None
Historical targets	Russia
Target industries	Financial Services, Local Government
Discovered	2025/2/10
Last active	2025/7/29
Motive	Data theft
ATT&CK techniques	0

Description

DarkGaboon has been active since May 2023 and was disclosed by PT SEC on January 22, 2025. Its targets are primarily Russian financial and treasury institutions. The group uses decoy documents carrying RevengeRAT malware to attack Russian financial departments.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
2	477	42	435	0

5.10 HeptaX

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2024/10/25
Last active	2025/2/27
Motive	Espionage
ATT&CK techniques	0

Description

HeptaX is an APT group that conducts cyber espionage primarily by exploiting unauthorized Remote Desktop Protocol (RDP) connections. The group distributes malicious LNK files via phishing emails; these files embed PowerShell and BAT scripts used to carry out multi-stage attacks.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	16	9	7	0

5.11 Emennet Pasargad

Geographic origin	Iran
Aliases	None
Historical targets	United States, Europe
Target industries	Infrastructure
Discovered	2020/1/1
Last active	2025/1/21
Motive	Data theft
ATT&CK techniques	0

Description

Emennet Pasargad is an Iranian cybercrime group, formerly known as Eeyelanet Gostar and Net Peygard Samavat Company. Active since 2020, it primarily targets network infrastructure in the United States, Europe, and other countries, particularly organizations with large customer bases. Emennet Pasargad's primary mode of operation is "hack-and-leak," compromising infrastructure to steal sensitive data and then amplifying that information on social media for greater impact.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	19	7	12	0

5.12 RansomHub

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Local Government, Financial Services, Healthcare
Discovered	2025/2/10
Last active	2025/4/29
Motive	Financial benefits
ATT&CK techniques	0

Description

RansomHub is operated by the hacking group Greenbottle and has been active since February 2024, rapidly becoming one of the most aggressive Ransomware-as-a-Service (RaaS) operations globally. It attracts affiliates by offering higher revenue shares (paid out directly from ransoms paid by victims) and expands its attack surface using custom tooling (such as the Betruger backdoor) and public vulnerabilities. The group also uses BYOVD techniques to disable security softwares such as EDRKillShifter.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	51	0	51	0

5.13 BladedFeline

Geographic origin	East Asia
Aliases	None
Historical targets	Iraq, Kurdistan Region
Target industries	Government, Military Industry, High-tech Enterprises, Financial Institutions
Discovered	2022/9/9
Last active	2025/7/7
Motive	Espionage
ATT&CK techniques	0

Description

BladedFeline is an APT group with a suspected East Asian state nexus, primarily conducting long-term cyber espionage against government, defense, high-tech enterprise, and financial institution targets. The group was first discovered by security researchers in 2022 and remains active; its name derives from the distinctive code identifiers used in its attack tooling and its “blade-like” precise and stealthy attack techniques.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	5	0	5	0

5.14 PassiveNeuron

Geographic origin	Unknown
Aliases	None
Historical targets	Latin America, East Asia
Target industries	Government
Discovered	2024/11/1
Last active	2025/10/23
Motive	Unknown
ATT&CK techniques	0

Description

The cyber espionage group was first identified in November 2024, with a series of attacks against government entities in Latin America and East Asia observed as early as June 2024. The attacks used two previously undiscovered malware families, designated Neursite and NeuralExecutor. Kaspersky also noted that the operation exhibited a high degree of technical sophistication: the threat actor used compromised internal servers as intermediary C2 infrastructure to evade detection.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	7	0	7	0

5.15 SafePay

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2024/11/1
Last active	2025/7/9
Motive	Financial benefits
ATT&CK techniques	0

Description

SafePay was first identified in November 2024 and has since become one of the most aggressive ransomware groups in recent months. SafePay employs a double-extortion strategy, encrypting files while simultaneously exfiltrating sensitive data to further pressure victims into paying. Notably, SafePay's malware excludes Cyrillic-language systems, suggesting a possible connection to Russia-linked threat actors. The group employs aggressive negotiation tactics, including directly calling victims, and operates a “shame site” that publishes stolen data from victims who do not pay.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	3	0	3	0

5.16 UNC961

Geographic origin	Unknown
Aliases	Gold Melody, Prophet Spider, PROPHET SPIDER
Historical targets	United Kingdom, Germany, United States, Australia
Target industries	Financial Services, Manufacturing, Retail, High-tech, Transportation & Logistics, Medical Technology
Discovered	2017/12/1
Last active	2025/7/8
Motive	Unknown
ATT&CK techniques	0

Description

The Prophet Spider group (also tracked as UNC961 and Gold Melody) was first observed active in 2017, with its tradecraft maturing after 2019. The group remained active through 2025, with attacks concentrated on financial, manufacturing, retail, high-tech, transportation and logistics, and medical technology organizations in Europe (UK, Germany), the United States, and Australia. It primarily gains victim access by compromising vulnerable web servers, typically exploiting various publicly disclosed vulnerabilities. The actor most likely functions as an access broker in many instances, handing off access to third parties for ransomware deployment.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
2	1	1	0	0

5.17 mre1903

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2018/6/1
Last active	2025/7/4
Motive	Unknown
ATT&CK techniques	0

Description

Multiple browser extensions associated with mre1903 employ similar deceptive tactics across various fake gaming extensions, with each extension disguised as a popular, well-known game to exploit users' familiarity and trust. mre1903 has been registered since June 2018, and most of its malicious gaming extensions were published around December 2020. Although these extensions have been active for more than four years, they illustrate the persistent presence of long-term threat actors within the browser extension ecosystem.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	0	0	0	0

5.18 Water Gamayun

Geographic origin	Unknown
Aliases	None
Historical targets	Ukraine
Target industries	Enterprise, Government
Discovered	2025/11/25
Last active	2025/11/25
Motive	Unknown
ATT&CK techniques	0

Description

Water Gamayun is a Russia-aligned APT group whose core motives are strategic intelligence collection, credential theft, and long-term persistence, targeting enterprises, government bodies, and other entities with geopolitical or commercial value. The group commonly employs zero-day vulnerabilities (such as CVE-2025-26633), trusted-binary proxy execution, and layered PowerShell obfuscation, delivering malicious payloads through compromised legitimate websites, lookalike domains, and double-extension decoy files (such as .pdf.rar). It maintains a high standard of operational security, for example using 21-character strong passwords to protect archives.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	8	2	6	0

5.19 Bloody Wolf

Geographic origin	Unknown
Aliases	None
Historical targets	Central Asia, Russia
Target industries	Government
Discovered	2023/12/1
Last active	2025/11/26
Motive	Unknown
ATT&CK techniques	0

Description

Bloody Wolf is an APT group active since late 2023, initially using STRRAT malware before shifting to weaponizing the legitimate NetSupport RAT for targeted attacks. Its core targets are government agencies in Central Asia (Kazakhstan, Kyrgyzstan, Uzbekistan) and Russia. The group delivers malicious JAR files via phishing PDFs disguised as government documents, employing geofencing and multiple persistence mechanisms to achieve remote control and data theft with a high degree of stealth and precision targeting.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	73	11	62	0

5.20 TAG-150

Geographic origin	Unknown
Aliases	None
Historical targets	United States
Target industries	Unknown
Discovered	2025/3/1
Last active	2025/11/26
Motive	Unknown
ATT&CK techniques	0

Description

TAG-150 is a malware-as-a-service (MaaS) operator active since March 2025, primarily conducting multi-stage attacks using CastleLoader and CastleRAT, with targets concentrated in the United States. CastleLoader is an obfuscation-capable loader distributed through deceptive domains and fake GitHub repositories, used to download and execute subsequent malicious payloads. CastleRAT is a remote access trojan (including a Python variant, PyNightShade) capable of remote system control, command execution, keylogging, and screen cAPTure. As of May 2025, CastleLoader had infected at least 469 devices; its infrastructure includes C2 servers and other components, with the attack chain typically relying on tricking users into executing scripts to trigger infection.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	2	2	0	0

5.21 TA829

Geographic origin	Unknown
Aliases	RomCom, Void Rabisu, Tropical Scorpius
Historical targets	Unknown
Target industries	Unknown
Discovered	2019/9/11
Last active	2025/12/25
Motive	Unknown
ATT&CK techniques	0

Description

The cybercrime group TA829, also tracked under the aliases RomCom, Void Rabisu, and Tropical Scorpius, has been observed deploying sophisticated tactics, techniques, and procedures (TTPs), including an updated version of its notorious RomCom backdoor now known as SingleCamper (aka SnipBot). The group is known for combining financially motivated cybercrimes with espionage activities generally aligned with Russian state interests, and its operations underwent significant changes during 2024 and 2025.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
3	13	10	3	0

5.22 UNC5174

Geographic origin	Unknown
Aliases	Uteus, UEtus, CL-STA-1015
Historical targets	Unknown
Target industries	Unknown
Discovered	2025/11/26
Last active	2025/11/26
Motive	Unknown
ATT&CK techniques	0

Description

UNC5174 (aka Uteus) is a group capable of maintaining long-term control over targets, employing a “multi-round backdoor deployment” strategy: first compromising a target using an older backdoor such as VShell, then deploying a stealthier new backdoor to reduce exposure. In this campaign, the group developed a Discord bot backdoor using the open-source Golang library discordgo, using the Discord API as a C2 channel (reusing legitimate platform traffic to evade detection). The backdoor supports command execution, file upload/download, and system information collection, with an extremely low malware detection rate (only 1/64 on VirusTotal), aiming to maintain long-term control over victim devices.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	1	0	1	0

5.23 GOLD BLADE

Geographic origin	Unknown
Aliases	RedCurl, RedWolf, EarthKapre
Historical targets	Canada, United States
Target industries	Services, Manufacturing
Discovered	2018/1/1
Last active	2025/12/5
Motive	Unknown
ATT&CK techniques	0

Description

GOLD BLADE (aka RedCurl, RedWolf, EarthKapre) is a specialized cyber threat group active since 2018 with no apparent state sponsorship or political motive. It initially operated as a “hacker-for-hire” conducting commercial espionage, before shifting in 2025 toward a hybrid “data theft plus selective extortion” model, monetizing intrusions with a custom QWCrypt ransomware variant. Its attacks show strong geographic concentration: in the STAC6565 campaign spanning February 2024 to August 2025, nearly 80% of targets were in Canada, followed by the United States, with victims spanning the services and manufacturing sectors, among others. Its activities follow a “dormancy-then-surge” pattern, with attack peaks in September 2024 and March/July 2025 following technical iterations. Technically, initial access evolved from phishing to abusing recruitment platforms such as Indeed to deliver malicious resumes; the group's core tool is RedLoader malware, and in July 2025 it developed an “LNK + WebDAV + DLL sideloading” attack chain. For defense evasion, it relies on BYOVD techniques (a modified Terminator tool plus the vulnerable Zemana driver) and even modifies the registry to disable Windows security mechanisms. Its C2 infrastructure uses RPivot/Chisel tools combined with Cloudflare Workers domains to conceal traffic. For extortion, it selects high-value targets for QWCrypt deployment (encrypting files with a .qwcrypt extension), erases traces, and mimics LockBit-style ransom notes.

While some third parties speculate the group may be Russian-speaking, there is no concrete evidence, and its membership and structure remain unknown. Overall, it operates on an “intrusion-as-a-service” model and represents a significant hybrid threat to North American enterprises.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	74	5	69	0

5.24 Silent Lynx

Geographic origin	Kazakhstan
Aliases	None
Historical targets	Unknown
Target industries	Financial Services, Local Government
Discovered	2025/1/22
Last active	2025/10/24
Motive	Data theft
ATT&CK techniques	0

Description

A new threat group named Silent Lynx has been identified targeting organizations in Kyrgyzstan and neighboring countries. The group employs a range of techniques, including malicious email attachments, decoy documents, and persistence mechanisms, to maintain access to compromised systems. Silent Lynx uses a sophisticated multi-stage attack methodology involving ISO files, a C++ loader, PowerShell scripts, and Golang implants, primarily targeting government entities, banks, and diplomatic missions, while leveraging United Nations-themed lures and employee bonus scheme decoys to deceive victims. For C2 and data exfiltration, Silent Lynx relies on Telegram bots.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
2	45	8	37	0

5.25 UAC-0006

Geographic origin	Unknown
Aliases	None
Historical targets	Ukraine
Target industries	Financial Services
Discovered	2003/2/6
Last active	2025/2/7
Motive	Financial benefits
ATT&CK techniques	0

Description

UAC-0006 is a financially motivated group that has been active since at least 2013. It primarily targets Ukrainian organizations, especially accountants, sending phishing emails carrying SmokeLoader malware. Its goal is to steal credentials and execute unauthorized fund transfers, posing significant risks to the financial system.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	54	20	34	0

5.26 Water Makara

Geographic origin	Unknown
Aliases	None
Historical targets	Brazil
Target industries	Financial Services
Discovered	2024/10/14
Last active	2025/2/11
Motive	Data theft
ATT&CK techniques	0

Description

Water Makara is an active cyberattack group that primarily conducts targeted attacks against organizations in Brazil. The group uses Astaroth malware, distributed via phishing emails disguised as official tax notices or compliance documents.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	86	86	0	0

5.27 UNC4221

Geographic origin	Russia
Aliases	UAC-0185
Historical targets	Ukraine
Target industries	National Defense
Discovered	2022/12/1
Last active	2025/3/5
Motive	Espionage
ATT&CK techniques	0

Description

UNC4221 (aka UAC-0185) is a suspected Russia-linked APT group that has remained continuously active since 2022, primarily targeting Ukraine's defense industrial base, military sector, and members of the defense forces. The group distributes malicious LNK files through phishing emails disguised as official organizations (such as the Union of Ukrainian Industrialists and Entrepreneurs), triggering multi-stage infection chains that ultimately deploy the MESHAGENT remote access trojan (RAT) to control compromised systems.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
2	32	28	4	0

5.28 TA2726

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2022/9/20
Last active	2025/2/20
Motive	Unknown
ATT&CK techniques	0

Description

This group has been active since at least September 2022. Like other compromised-website groups, it does not conduct dedicated email campaigns; any activity observed in email is purely incidental — that is, the compromised websites are shared legitimately within emails, with senders unaware they have been weaponized. As of 2025, TA2726's traffic distribution system (TDS) has been observed redirecting traffic to TA569 (in North America), while redirecting most other regions to TA2727, delivering LummaStealer (Windows), DeerStealer (Windows), FrigidStealer (Mac), or Marcher (Android).

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	12	7	5	0

5.29 Storm-0408

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2024/12/2
Last active	2025/3/10
Motive	Unknown
ATT&CK techniques	0

Description

Storm-0408 has launched a large-scale malvertising attack designed to steal sensitive information. The attack involves multiple remote access or information-stealing malware families, distributed via phishing, SEO poisoning, or malicious advertising. The attack originates from illegal streaming websites embedding malicious ad redirectors; users are redirected to an intermediary site and then funneled to GitHub and two other platforms. The attack is estimated to have affected more than one million devices worldwide, reflecting its indiscriminate, mass-targeting nature.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	161	40	121	0

5.30 Mysterious Elephant

Geographic origin	South Asia
Aliases	None
Historical targets	Pakistan, Bangladesh, Myanmar
Target industries	Local Government, National Government
Discovered	2023/4/1
Last active	2025/3/18
Motive	Espionage
ATT&CK techniques	0

Description

Mysterious Elephant is an APT group with a suspected South Asian nexus, first formally named by Kaspersky in its 2023 Q2 APT trends report. The group primarily targets Pakistani diplomatic institutions, defense and military departments, and government organizations, while also expanding its targeting to other South Asian countries and regions such as Bangladesh and Myanmar. Its operations center on social engineering, using phishing documents themed around trending topics (such as CHM files) as initial payloads, employing double extensions (e.g., “.pdf.chm”) to disguise files as legitimate and deceive victims. Its attack chains frequently use encrypted archives to conceal C#-based backdoors capable of executing commands issued by a C2 server, including file theft and system information collection.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	34	10	24	0

5.31 Storm-1865

Geographic origin	Unknown
Aliases	None
Historical targets	North America, Oceania, South Asia, Southeast Asia, Northern Europe, Southern Europe, Eastern Europe, Western Europe
Target industries	Entertainment
Discovered	2024/12/13
Last active	2025/3/14
Motive	Financial benefits
ATT&CK techniques	0

Description

This group impersonates the online travel agency Booking.com and conducts phishing campaigns against the hospitality industry. The campaign uses a social engineering technique known as ClickFix to deliver various credential-stealing malware for financial fraud and theft. Targeting individuals at hospitality organizations across North America, Oceania, South Asia, and Southeast Asia, as well as Northern, Southern, Eastern, and Western Europe, the group most likely targets organizations that partner with Booking.com, sending fraudulent emails purporting to come from the platform.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	11	8	3	0

5.32 UAT-5918

Geographic origin	Unknown
Aliases	None
Historical targets	Taiwan,China
Target industries	Infrastructure, Healthcare, Telecommunications
Discovered	2025/3/20
Last active	2025/4/22
Motive	Data theft, Ideology
ATT&CK techniques	0

Description

UAT-5918 is a suspected state-sponsored APT group that primarily targets critical infrastructure in Taiwan, China (such as telecommunications, healthcare, and IT). It gains initial access by exploiting unpatched server vulnerabilities and deploys web shells and open-source tools (such as FRP and Mimikatz) to achieve persistence, information theft, and lateral movement. Its tactics and tooling overlap in part with APT groups such as Volt Typhoon and Flax Typhoon.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	25	0	25	0

5.33 Swan Vector

Geographic origin	Unknown
Aliases	None
Historical targets	Taiwan, China and Japan
Target industries	Education, Mechanical Engineering
Discovered	2025/5/12
Last active	2025/5/23
Motive	Unknown
ATT&CK techniques	0

Description

Researchers uncovered a group dubbed Swan Vector that has been targeting East Asian countries and regions, including Taiwan, China and Japan. The group primarily targets educational institutions and the mechanical engineering industry, with its decoys designed to appear as fake candidate resumes.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	12	1	11	0

5.34 Night Eagle

Geographic origin	United States
Aliases	APT-Q-95, APT-C-78
Historical targets	China
Target industries	Technology, Military Industry, Semiconductors, Quantum Technology, Artificial Intelligence
Discovered	2023/7/4
Last active	2025/7/15
Motive	Unknown
ATT&CK techniques	0

Description

Night Eagle (tracked as APT-Q-95/APT-C-78) is a highly elusive APT group whose activity dates back to at least 2023, primarily conducting long-term intelligence theft against China's core high-tech industry, defense industry, semiconductor, quantum technology, and artificial intelligence sectors.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
2	41	41	0	0

5.35 Famous Chollima

Geographic origin	North Korea
Aliases	None
Historical targets	Unknown
Target industries	Cryptocurrency, Blockchain
Discovered	2024/6/1
Last active	2025/10/20
Motive	Unknown
ATT&CK techniques	0

Description

Famous Chollima is a North Korea-linked group active since mid-2024, specializing in distributing malware through fake recruitment processes (such as “skills assessment” pages). Its attack chain involves cross-platform remote access trojans (such as GolangGhost and its Python variant, PylangGhost), primarily targeting professionals in the cryptocurrency and blockchain sectors, with recent activities concentrated in India.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
3	83	48	35	0

5.36 Stargazers Ghost Network

Geographic origin	Russia
Aliases	None
Historical targets	Unknown
Target industries	Entertainment
Discovered	2023/6/18
Last active	2025/6/18
Motive	Unknown
ATT&CK techniques	0

Description

Stargazers Ghost Network was first documented in June 2023, with its most recent activities observed in June 2025. The attackers commit GitHub code in the UTC+3 time zone, and malicious files contain Russian comments, primarily targeting global gamers, particularly using “cheat tools” to attract young users, with over 1,500 cumulative infection attempts recorded. The group's attack infrastructure relies on GitHub repositories to host malicious JAR files, Pastebin to store commands, and Russian-language domains to distribute payloads, forming a “Distribution-as-a-Service” (DaaS) attack chain. The campaign has stolen browser passwords, cryptocurrency wallet contents, and Discord authentication tokens from victims' systems.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	19	4	15	0

5.37 amdc6766

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Information Technology
Discovered	2023/8/18
Last active	2025/8/18
Motive	Unknown
ATT&CK techniques	0

Description

amdc6766 is an APT group active since 2023, primarily targeting IT operations personnel. Through supply-chain poisoning and distribution of cracked software, it implants remote-control trojans on Windows, Linux, and macOS systems to conduct data theft and lateral movement.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
2	61	44	17	0

5.38 Funnull

Geographic origin	Unknown
Aliases	None
Historical targets	North America, Europe, Asia
Target industries	Government, Finance, Technology, Telecommunications
Discovered	2022/1/1
Last active	2025/7/1
Motive	Unknown
ATT&CK techniques	0

Description

Funnull was established in 2022 and remained active as of July 2025. Its primary targets span North America, Europe, and parts of Asia, with a focus on attacking government, financial, technology, and telecommunications sectors, leveraging DNS tunneling techniques to achieve highly covert attack behaviors. The group's technical methods continue to evolve, combining domain generation algorithms with multi-layered proxy servers to increase the complexity of its attack chain and the difficulty of defense.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	62	62	0	0

5.39 RedDirection

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2025/3/1
Last active	2025/7/10
Motive	Unknown
ATT&CK techniques	0

Description

This group's first activity was observed in March 2025, with its most recent activity in July 2025. It specializes in supply-chain attacks, initially publishing functional extensions to obtain official Google/Microsoft certification (verification badges and store recommendations), then lying dormant for months before implanting malicious code via version updates. The group excels at weaponizing user trust and exploiting extension update mechanisms to bypass review.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	9	9	0	0

5.40 UTG-Q-1000

Geographic origin	Unknown
Aliases	None
Historical targets	Unknown
Target industries	Unknown
Discovered	2024/11/10
Last active	2025/11/13
Motive	Unknown
ATT&CK techniques	0

Description

The cybercriminal group UTG-Q-1000 is organized into four distinct “teams”: a financial team, a tabloid/clickbait team, a design and manufacturing team, and a honeypot/black-on-black team. The “financial team” has a clear division of labor and well-defined targets, specializing in targeting financial and management personnel at enterprises and institutions, aiming to steal sensitive financial information or profit directly through fraud. Its attack methods are highly deceptive, specializing in crafting highly realistic phishing content, often disguised as themes closely related to financial work such as “tax audits,” “electronic invoices,” “subsidy announcements,” “company rosters,” and “personnel reassignments,” to trick victims into downloading and running trojans.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
1	7	5	2	0

5.41 Medusa

Geographic origin	Unknown
Aliases	None
Historical targets	United States, United Kingdom, Canada, Australia
Target industries	Healthcare, Financial Services, Education
Discovered	2021/6/2
Last active	2025/4/11
Motive	Financial benefits
ATT&CK techniques	5

Description

The Medusa ransomware group is a financially motivated criminal organization operating the Medusa ransomware, a Ransomware-as-a-Service (RaaS) offering primarily targeting Windows systems, active since June 2021. The group primarily attacks healthcare, manufacturing, and education sectors, with victims spanning the United States, United Kingdom, Canada, and Australia. Its attack methods include exploiting software vulnerabilities and hijacking legitimate accounts for initial access, using remote monitoring tools (such as AnyDesk) to maintain persistence, leveraging Bring Your Own Vulnerable Driver (BYOVD) techniques to disable antivirus software, and using scheduled tasks for persistence. Medusa employs a double-extortion strategy, exfiltrating data before encrypting it and threatening to publish sensitive information to pressure victims into paying. Its attack activity increased by 42% between 2023 and 2024 and continued to grow into early 2025.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
3	8	2	6	0

5.42 APT-C-60

Geographic origin	East Asia
Aliases	None
Historical targets	South Korea, China
Target industries	Local Government, Trade
Discovered	2018/1/1
Last active	2025/6/18
Motive	Espionage
ATT&CK techniques	0

Description

APT-C-60 is an APT group active in East Asia, operating since 2018 and believed to be based in South Korea. The group primarily conducts cyberattacks against government agencies, the trade industry, and think tanks in countries such as China and South Korea, among other high-value targets. APT-C-60 is skilled in using a variety of attack techniques, including phishing emails, vulnerability exploitation, and persistence mechanisms.

Knowledge correlation

Reports	Threat indicators	Network infrastructure	Malware samples	Exploited vulnerabilities
3	25	3	22	7

6. Outlook on Future Threat Trends

Reviewing the year 2025, global APT attacks underwent profound transformations across multiple dimensions including AI empowerment, geopolitical conflicts and supply chain infiltration. Looking ahead, fueled by emerging technologies, these trends will intensify further, bringing unprecedented challenges to the global cybersecurity landscape.

6.1 AI Will Shift from Auxiliary Tool to Core Orchestrator, Enabling Fully Intelligent Attacks

AI technologies are evolving from auxiliary tools for APT operations into a core driving force, fueling the comprehensive upgrade of attacks from automation to full intelligence.

Sustained surge in effectiveness of AI-driven attacks

In 2025, the volume of activities conducted by AI-enabled threat actors jumped 89% year-on-year. AI has been widely deployed in core attack phases such as reconnaissance, credential theft and detection evasion.

In the future, APT operations will transition from AI-assisted to AI-orchestrated: threat actors will leverage artificial intelligence to independently complete reconnaissance, malware generation, lateral movement and data exfiltration. Some government-linked APT groups have already realized autonomous execution of 80%–90% of their attack workflows. Industry forecasts predict that by 2026, APT campaigns will evolve along two major trajectories: AI-driven operations and cross-group coordinated strikes, rendering adversarial tactics far more difficult to trace.

AI systems become new attack surfaces

Attackers have injected malicious prompts into GenAI platforms used by over 90 organizations. They exploit vulnerabilities within AI development frameworks to establish persistent footholds and deploy ransomware. Forecasts indicate state-backed attackers will increasingly deploy backdoored AI tools, and attacks targeting AI infrastructure will become commonplace.

Agentic AI spawns new insider threats

As enterprises widely adopt AI agents to automate workflows, such agents holding privileged access credentials across multiple systems, if compromised, will act as digital spies lurking within corporate networks. Attackers can hijack these agents to steal massive credential datasets and breach disparate systems. The definition of insider threats will expand drastically in the future, no longer limited to malicious human employees. Compromised AI agents and AI-forged identities will constitute emerging internal threat vectors.

6.2 Weaponization of Zero-Day Vulnerabilities Will Accelerate, Shrinking Response Time Window

The speed and scope of zero-day exploitation will keep expanding, further compressing the response window available to defensive teams.

Record-breaking vulnerability exploitation speed

In 2025, the average breakthrough time (from initial access to lateral movement) for cybercriminals was cut down to 29 minutes, representing a 65% improvement over 2024. The fastest intrusion took merely 27 seconds, with data exfiltration initiated within four minutes of initial compromise in certain incidents. The handover of stolen initial access credentials among criminal collectives has been shortened from hours to just 22 seconds, drastically narrowing the window for defense response. AI is reshaping the entire attack lifecycle, slashing preparation time from weeks to hours and producing far more deceptive malicious content.

Enterprises become primary attack targets

For the first time in 2025, enterprise as victims accounted for 48% of all zero-day vulnerabilities exploited in-the-wild activities. Edge devices such as VPN gateways, firewalls and identity management systems were top targets.

Vulnerability exploitation has remained the most prevalent initial access vector worldwide

for six consecutive years, responsible for 32% of all breaches. Enterprises will face mounting risks of zero-day exploits targeting their commercial products in the coming years.

AI-empowered vulnerability hunting

Threat actors are leveraging AI to automate vulnerability hunting. Industry reports predict zero-day exploitation will remain rampant in 2026, as AI drastically lowers the technical barrier for flaw discovery and exploit development, narrowing the capability gap between seasoned hackers and opportunistic cybercriminals.

6.3 Supply Chain Attacks Will Upgrade, with Open-Source Ecosystems Turning Primary Targets

Supply chain attacks will remain a favored entry point for attackers due to their 'single-point breach, full-network compromise' nature.

Open-source repository poisoning becomes routine

Multiple APT groups abused open-source code repositories in their 2025 attacks. Threat actors created backdoor-laden software projects and packages to trick developers into integration, achieving supply chain compromise. Statistics show 56% of supply chain attacks stemmed from poisoned open-source artifacts. Forecasts project a continuous rise in such attacks throughout 2026.

Cloud-supply chain integration expands systemic attack surface

As enterprises complete large-scale cloud migration, misconfigured cloud resources and excessive privilege abuse will create critical breach vectors. Attackers exploit third-party SaaS integration modules to exfiltrate and transfer data in cloud environments, maintaining multi-year persistent presence. The convergence of cloud platforms and supply chains will expand attack surfaces systemically, posing severe risks to national digital sovereignty and critical infrastructure security.

6.4 Geopolitically Motivated APT Activities Will Escalate, with Critical Infrastructure Becoming Main Battlefield

APT attacks will become more closely intertwined with geopolitical rivalries, shifting adversary priorities from intelligence theft to high-impact sabotage against critical infrastructure.

Deep integration of cyber operations and military actions

Cyberattacks have evolved into core geopolitical instruments. Amid the Russia-Ukraine, Iran-Israel and other conflicts, cyber operations are tightly coupled with military strikes. In late December 2025, Russia-linked Sandworm group launched one of the most destructive attacks against Polish power grids, deploying DynoWiper data wiper malware. DDoS attacks remain a staple tactic for geopolitically aligned threat actors, whose operations transcend national borders and impact victims across Europe, the U.S., India, Vietnam, Argentina and other regions.

Critical infrastructure remains top target

Manufacturing, healthcare and utility sectors face growing risks as ransomware-as-a-Service (RaaS) operators expand their attack scope into Operational Technology (OT) environments. Criminal groups repurpose firmware corruption and device bricking techniques for financial extortion. Compromised Agentic AI may disrupt supply chains, steal funds or cripple core infrastructure. With sustained geopolitical tensions, attacks targeting energy, transportation and communications infrastructure are expected to escalate further.

6.5 Cloud & Identity Attacks Will Become New Frontlines

Widespread cloud adoption and the complexity of identity management will turn cloud security and credential-based attacks into the central arena of future cyber offense and defense.

Persistent surge in cloud breaches

Attackers increasingly infiltrate environments via trusted identities and SaaS applications,

blending malicious activity with legitimate traffic while shortening defense response windows. The time gap between cloud compromise and irreversible damage has contracted from days to minutes, and AI-powered privilege escalation scripts can be triggered within seconds once cloud workloads are breached.

Identity attacks dominate attack vectors

Credential theft has surpassed phishing emails to become the world's second most common attack vector, and ranks first for cloud breaches. Abuse of legitimate user accounts has been attackers' preferred tactic, responsible for 35% of all cloud security incidents. Attackers are increasingly acquiring valid credentials from initial access broker (IAB) markets. Coupled with high-privilege AI agents, any Agents hijacking could easily turn them into a new type of insider pivoting node.

Fileless attacks & SaaS compliance risks worsen

Fileless attacks have become commonplace, as nearly 80% of breaches are free of traditional malware binaries. Third-party SaaS platforms constitute major risk vectors: attackers abuse built-in SaaS integration functions to steal and exfiltrate data, sustaining multi-year covert persistence. Improper cloud configuration has been among the most frequent entry points for cloud breaches.

In summary, the above five major trends will define global APT threats in the foreseeable future: AI dominating the full attack lifecycle, accelerated zero-day weaponization, deepening supply chain infiltration, intensifying geopolitical cyber conflicts, and cloud & identity security emerging as major battlefields.

Faced with increasingly sophisticated, organized and intelligent attacks, defense teams must accelerate the development of AI-versus-AI proactive defense capabilities. Combined with zero-trust architecture, supply chain governance, cloud-native protection and critical infrastructure resilience, defense teams can complete the transformation from passive incident response to an integrated "prediction-prevention-response-recovery" defense framework, fully boosting capabilities to counter nation-level and organized APT activities.

ABOUT CYBERSPACE INSTITUTE OF ADVANCED TECHNOLOGY, GUANGZHOU UNIVERSITY

Founded in July 2022, Cyberspace Institute of Advanced Technology upholds the university motto of "To study extensively, practice earnestly and advance with the times". Guided by the three driving forces proposed by Honorary Dean Academician Fang Binxing — academic-driven, guideline-driven, and market-driven, the institute shoulders the mission of cultivating top-tier cyberspace security talents to serve the nation. Its core goals are to deliver urgently needed, world-class, irreplaceable research outcomes for the country, spearhead industrial technological advancement, and continuously build a first-class faculty team and high-standard research platforms.

The institute has 71 full-time faculty members, including 31 professors, 21 associate professors, 14 lecturers and 5 postdoctoral researchers. The institute is authorized to confer doctoral and master's degrees in the first-level discipline of Cyberspace Security. The discipline of the institute has been selected as a Key Discipline with Distinct Advantages of Guangdong Province and a Key Construction Discipline under the "Enhancement, Reinforcement and Improvement" Initiative for High-Level Universities in Guangdong Province. It ranked 3rd nationwide in the 2025 Shanghai Ranking of Chinese Universities by Subject.

Currently, the institute hosts 104 doctoral students, 619 master's students and 509 undergraduate students. Relying on the institute, the Academician Fang Binxing Laboratory Program runs dedicated graduate classes and offers preparatory tracks for undergraduates. Through integrated undergraduate-postgraduate training, the institute fosters practical and innovative talents.

ABOUT NSFOCUS

NSFOCUS, Inc., a pioneering leader in cybersecurity, is dedicated to safeguarding telecommunications, Internet service providers, hosting providers, and enterprises from sophisticated cyberattacks.

Founded in 2000, NSFOCUS operates globally with over 3,000 employees at two headquarters in Beijing, China, and Santa Clara, CA, USA, and over 50 offices worldwide. It has a proven track record of protecting over 25% of the Fortune Global 500 companies, including four of the five largest banks and six of the world's top ten telecommunications companies.

Leveraging technical prowess and innovation, NSFOCUS delivers a comprehensive suite of security solutions, including the Intelligent Security Operations Platform (ISOP) for modern SOC, Volumetric DDoS Protection, Continuous Threat Exposure Service (CTEM) and Web Application and API Protection (WAAP). All the solutions and services are augmented by the Security Large Language Model (SecLLM) and other cutting-edge research achievements developed by NSFOCUS.

COPYRIGHTS

Unless otherwise specified, any text descriptions, document formats, illustrations, photos, methods, processes and other contents in this article are copyrighted by NSFOCUS and protected by relevant property rights and copyright laws. No individual or institution is allowed to copy or quote any part of this document in any way without the written authorization and permission of NSFOCUS.

WEBSITE
www.nsfocusglobal.com

© 2026 NSFOCUS